

Sysmon Nedir?

Microsoft'un Sysinternals araç ailesinin bir parçasıdır. Windows sistemlerinde gerçekleşen olayları varsayılan Windows loglarından daha ayrıntılı şekilde kaydetmek için kullanılır.

Varsayılan Windows logları ile farkı:

Windows'un kendi olay kayıtları; kullanıcı girişleri, hesap işlemleri ve sistem olayları gibi bilgileri kaydeder. Ancak saldırı analizi için gerekli olan hangi prosesin çalıştığı, hangi komut satırıyla çalıştırıldığı, hangi üst proses tarafından başlatıldığı, hangi ağ bağlantısının kurulduğu veya hangi dosyanın oluşturulduğu gibi ayrıntılar her zaman yeterli düzeyde değildir.

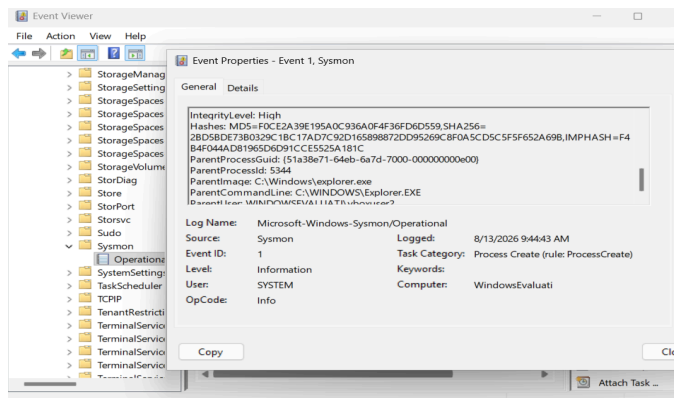
Sysmon bunu tamamlar. Örneğin bir proses oluşturulduğunda Process Create (Event ID 1) kaydı üzerinden prosesin kendisi, komut satırı, kullanıcı ve üst proses bilgileri görülebilir.

Sysmon bir güvenlik ürünü veya engelleme mekanizması değildir. Sistemde gerçekleşen aktiviteleri ayrıntılı şekilde kaydeden bir görünürlük aracıdır. Şüpheli bir işlemi kendisi durdurmaz veya engellemez.

Bu kayıtlar daha sonra SOC analisti, SIEM veya başka bir tespit sistemi tarafından analiz edilerek şüpheli aktivitelerin belirlenmesinde kullanılabilir.

Sysmon Loglarının Konumu:

Applications and Services Logs / Microsoft / Windows / Sysmon / Operational



Log Gürültüsü:

Sysmon yapılandırma dosyası, sistemde hangi olayların kaydedileceğini belirler. Bu nedenle yalnızca neyin kaydedileceğini değil, aynı zamanda neyin kaydedilmeyeceğini de belirler. Çok fazla olayın kaydedilmesi log gürültüsüne, çok az olayın kaydedilmesi ise görünürlük kaybına neden olabilir.

Sysmon kayıtları Event ID değerleriyle sınıflandırılır. Örneğin:

- **Event ID 1:** Process Create
- **Event ID 3:** Network Connection
- **Event ID 11:** File Create
- **Event ID 22:** DNS Query

Process Create – Event ID 1

Event ID 1, Sysmon'un en önemli kayıtlarından biridir. Bir proses oluşturulduğunda aşağıdaki bilgileri sağlayabilir:

- **Image:** Çalıştırılan programın yolu
- **CommandLine:** Programın hangi komut satırıyla çalıştırıldığı
- **User:** Prosesin hangi kullanıcı tarafından çalıştırıldığı
- **ParentImage:** Prosesin hangi üst proses tarafından başlatıldığı
- **ParentCommandLine:** Üst prosesin hangi komut satırıyla çalıştırıldığı
- **UtcTime:** Olayın gerçekleştiği zaman

Özellikle ParentImage (üst proses) bilgisi saldırı analizinde önemlidir. Çünkü yalnızca hangi programın çalıştırıldığını değil, hangi program tarafından başlatıldığını da gösterir.

Uygulama Çalışması:

Event ID 11 – File Create

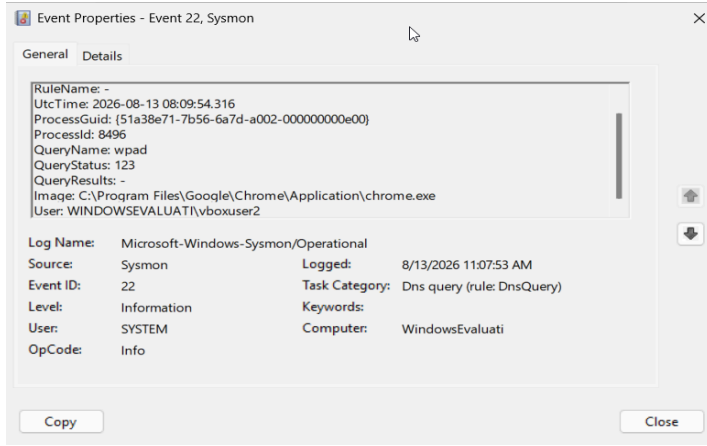
sysmon-test.txt isimli bir dosya oluşturdum ve dosyanın sistemde oluştuğunu kontrol ettim. Ancak Sysmon kayıtlarında bu dosyaya ait bir Event ID 11 kaydı bulunamadı.

Daha sonra kullandığım sysmonconfig-export.xml dosyasındaki FileCreate kurallarını inceledim. Dosya oluşturma olaylarının her dosya için kaydedilmediğini, belirli dosya türleri ve konumların filtrelendiğini gördüm. .txt dosyasının kaydedilmemesinin Sysmon'un çalışmamasından değil, yapılandırma dosyasındaki filtreleme kurallarından kaynaklandığını belirledim.

Bu işlem, fazla kayıt tutulduğunda gürültünün, fazla kısıtlama yapıldığında ise görünürlük kaybının oluşabileceğini göstermiş oldu.

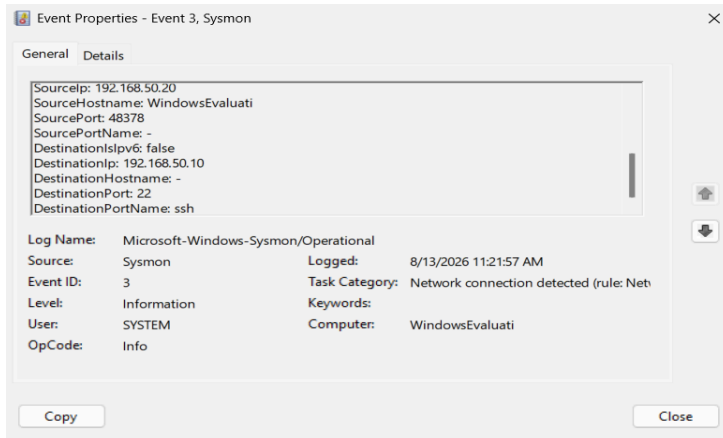
Event ID 22 – DNS Query

Chrome üzerinden Microsoft sitesine girerken Sysmon kaydında chrome.exe tarafından yapılan wpad DNS sorgusunu gördüm. Bu kayıt, DNS sorgularının da Sysmon üzerinden takip edilebildiğini gösterdi.



Event ID 3 – Network Connection

Windows'tan Ubuntu'ya SSH bağlantısı kurdum. Sysmon'da Event ID 3 kaydını inceleyerek bağlantının Ubuntu'nun 192.168.50.10 adresine ve 22 numaralı SSH portuna yapıldığını gördüm. Bu kayıt sayesinde ağ bağlantısının hangi proses tarafından oluşturulduğu ve hedef adres/port bilgileri görülebiliyor.



Nmap Taraması – Kaynak Makine

Windows'tan Ubuntu'ya Nmap taraması yaptım. Sysmon'da Event ID 3 üzerinden nmap.exe tarafından oluşturulan ağ bağlantısı kaydını gördüm. Kayıttaki Nmap'in UDP üzerinden 53 numaralı DNS portuna bağlantı oluşturduğu görüldü. Böylece tarama aracının çalıştığı kaynak makinede de Sysmon üzerinden iz bıraktığını gözlemledim.

Kaynak ve Hedef Karşılaştırması

- Kaynak makine: Taramayı yapan sistemdir. Sysmon üzerinden **nmap.exe** prosesinin oluşturduğu ağ bağlantıları görülebilir.
- Hedef makine: Kendisine gelen tarama trafiğini ve bağlantı denemelerini görür.

- Kaynak tarafında hangi prosesin bağlantıyı oluşturduğu ve hangi hedeflere bağlantı kurduğu incelenebilir.
- Hedef tarafında hangi IP'den bağlantı geldiği ve hangi portların hedeflendiği incelenebilir.
- İki tarafın birlikte incelenmesi, olayın hem kaynağını hem de hedef üzerindeki etkisini anlamayı kolaylaştırır.

Görünürlük ve Engelleme

- Sıkılaştırma (hardening): Bir olayın gerçekleşmesini engellemeye veya zorlaştırmaya çalışır.
- Sysmon / görünürlük: Olay gerçekleştiğinde ne olduğunu ayrıntılı şekilde kaydeder.
- Sysmon tek başına saldırıyı engellemez; kayıtları analist veya SIEM tarafından incelenir.
- Sıkılaştırma önleme, Sysmon ise izleme ve tespit tarafındadır.
- Biri diğerinin yerine geçmez. İkisi birlikte kullanıldığında hem saldırının gerçekleşmesi zorlaştırılır hem de gerçekleşen olayların izleri görülebilir.
- İkisi de olmayan bir sistemde saldırganın hem hareket alanı genişler hem de olay sonrasında inceleme yapılabilecek kayıtlar azalır.